



Universiteit
Leiden
The Netherlands

Risk Management and Threat Modeling

Lecture Handout

Eleftheria Makri

2025-2026

1. Risk Management

- **Asset:** A major application, general support system, high impact program, physical plant, mission critical system, personnel, equipment, or a logically related group of systems.
- **Vulnerability (1):** Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source.
- **Vulnerability (2):** A weakness in a system, application, or network that is subject to exploitation or misuse.
- **Threat (1):** Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the Nation through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service.
- **Threat (2):** The potential source of an adverse event.
- **Threat (3):** Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service. Also, the potential for a threat-source to successfully exploit a particular information system.
- **Risk:** The level of impact on organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals resulting from the operation of an information system given the potential impact of a threat and the likelihood of that threat occurring.

An **asset** has a **vulnerability**; a **threat** can exploit this vulnerability; exploitation of a vulnerability has an **impact**. Assets, vulnerabilities, threats, and impacts are used to calculate the **risk**. Then **countermeasures** are deployed to reduce the risk.

- **Security and Risk Management Relationships:** Security management ensures the interrelationships among assessing risk, implementing policies and controls in response to the risks, promoting awareness of the expectations, monitoring the effectiveness of the controls, and using this knowledge as input to the next risk assessment.

2. Understand and Apply Risk Management Concepts

Risk management is a discipline for living with the possibility that future events may cause harm. Risk management reduces risks by defining and controlling threats and vulnerabilities. (NIST figure pp. 513)

Risk Assessment or (interchangeably) Risk Analysis is conducted by an organization to evaluate:

- Threats to its assets
- Vulnerabilities present in the environment
- The likelihood that a threat will be realized by taking advantage of an exposure (or probability and frequency when dealing with quantitative assessment)
- The impact that the exposure being realized will have on the organization
- Countermeasures available that can reduce the threat's ability to exploit the exposure or that can lessen the impact to the organization when a threat is able to exploit a vulnerability
- The residual risk (e.g., the amount of risk that is left over when appropriate controls are properly applied to lessen or remove the vulnerability)

Potentially an organization also documents evidence of countermeasure, called exhibit or just evidence, which provides audit trails.

Why to conduct a Risk Assessment?

Because the cost of protection should never be higher than the asset's value, while at the same time valuable assets, should not remain unprotected.

Security and Audit Frameworks and Methodologies: are resources to assist in the design and testing of a security program.

- **COSO (Committee of Sponsoring Organizations of the Treadway Commission):** fraudulent financial reporting was the initial target. It includes five areas of internal control:
 - Control environment
 - Risk assessment
 - Control activities
 - Information and communication
 - Monitoring
- **ITIL (IT Infrastructure Library):** is a set of 34 books to improve IT service management. It concerns best practices for IT core operational processes, and shows how the controls can be implemented for the service management IT processes.
- **COBIT (Control Objectives for Information and related Technology):** examines effectiveness, efficiency, confidentiality, integrity, availability, compliance and reliability. It integrates the risk frameworks:
 - CobiT 4.1
 - Val IT 2.0
 - Risk IT
 - IT Assurance Framework (ITAF)
 - Business Model for Information Security (BMIS)

- **ISO27000 (formally ISO17799/BS7799):** is the first international information security management standard by ISO (published as ISO17799:2005). It contains 134 information security controls based on 11 areas:
 - Information security policy
 - Organizing information security
 - Asset management
 - Human resources security
 - Physical and environmental security
 - Communications and operations management
 - Access control
 - Information systems acquisition, development, and maintenance
 - Information security incident management
 - Business continuity management
 - Compliance

Risk Assessment Methodologies: mainly qualitative methods particularly used by regulated industries, e.g., healthcare.

- **NIST SP 800-30, 800-39, and 800-66:** SP 800-66 specifically for HIPAA; 800-39 focuses on organizational risk management and 800-30 on information system risk management.

SP 800-30 Risk Assessment methodology process:

- System characterization
 - Vulnerability identification
 - Threat identification
 - Countermeasure identification
 - Likelihood determination
 - Impact determination
 - Risk determination
 - Additional countermeasures recommendations
 - Document results
- **CRAMM (CCTA Risk Analysis and Management Method):** staged and disciplined approach embracing both technical and non-technical aspects of security.
 - 3 Stages:**
 - Asset identification and valuation
 - Threat and Vulnerability Assessment
 - Countermeasure selection and recommendation
 - **Failure Modes and Effect Analysis:** born in hardware analysis, but can be used in software and system analysis and examines effects of failures at three levels:
 - Immediate level (part or module)
 - Intermediate level (process or package)
 - System-wide
 - **FRAP (Facilitated Risk Analysis Process):** makes narrow risk assessment; it prescreens systems, applications etc. to determine whether risk analysis is needed. It is low cost and easy to be conducted.

- **OCTAVE:** is a self-directed information security risk evaluation. The organization's people direct risk evaluation activities are responsible for making decisions about the organization's efforts to improve information security. An interdisciplinary team, called the analysis team, leads the evaluation. Criteria: principles (philosophy – e.g., self-direction), attributes (requirements – distinctive qualities, or characteristics of the evaluation; they are derived from principles, e.g., interdisciplinary team) and outputs (requirements – required results, outcomes of each phase)
- **Security Officers Management and Analysis Project (SOMAP):** Swiss non-profit organization with primary goal to run an open information security management project and maintain free and open tools and documentation. Developed handbook, guide and risk tool.
- **Spanning Tree Analysis:** creates a tree of all possible threats or faults of the system. Branches are general categories, which are pruned during the risk assessment, when they do not apply.
- **VAR (Value at Risk):** theoretically based, *quantitative* measure of information security risk. Aims to achieve the best balance between cost and risk.

Qualitative Risk Assessments are descriptive versus measurable. For measurable results there are quantitative methodologies. Qualitative assessments are preferred when:

- Risk assessors have limited expertise
- Short timeframe
- Implementation is typically easier
- Non-significant amount of data readily available
- Assessors are long-term employees with experience with business critical systems

Management approval is needed prior to the assessment, and management is being continuously kept up-to-date. The assessment team requests documentation including:

- Information security program strategy
- Information security policies, procedures, guidelines, and baselines
- Information security assessments and audits
- Technical documentation (e.g., network diagrams, vulnerability assessment findings, etc.)
- Applications documentation, e.g., software development life cycle
- Business continuity and disaster recovery plans
- Security incident response plan
- Data classification schemes
- Business unit procedures
- Executive mandates
- Other documentation, as needed

The team organizes interviews for identifying vulnerabilities, threats and countermeasures, from all levels of staff. Once interviews are completed the analysis of the data can begin, matching threats to vulnerabilities, threats to assets and so forth.

Risk is defined as the product of likelihood and impact. Once risk is determined additional countermeasures are adopted to minimize, transfer or avoid the risk. Finally, the residual risk is calculated.

Quantitative Risk Assessments are conducted by more sophisticated in their data collection and retention organizations. They are numeric in nature, defining frequency, probability, impact, countermeasures effectiveness etc. as a discrete mathematical value. Often, risk assessment is a combination of qualitative and quantitative methods. Qualitative Assessments are conducted in 3 steps:

- Initial management approval
- Construction of a risk assessment team
- Review of the information currently available within the organization

Calculations focus on:

- Single loss expectancy (SLE): $SLE = \text{asset value (in \$)} \times \text{exposure factor (loss due to successful threat exploit, as a \%)}$
- Annualized rate of occurrence (ARO): How often in a year a threat will exploit a vulnerability
- Annualized Loss Expectancy (ALE): $ALE = SLE \times ARO$
- Geographically adjusted by local annual frequency estimate (LAFE) or standard annual frequency estimate (SAFE).
- Finally, compare the cost of a risk versus the cost of a countermeasure. **The cost of a countermeasure should NEVER be higher than the risk cost!!!**

3. Identify Threats and Vulnerabilities & Conduct Risk Assessment/Analysis

Vulnerability assessments focus on technology aspects, often using software tools for data collection. The assessor must properly read, understand, digest and present the information obtained in a nontechnical audience. **False-positives:** reported when there is no true vulnerability. **False-negatives:** unreported true (existing) vulnerabilities.

Threat Categories:

- Human
- Natural
- Technical
- Physical
- Environmental
- Operational

Selecting Tools and Techniques for Risk Assessment has to be done based on the best fit with the organization's culture, personnel capabilities, budget and timeline. Automated tools may or may not be used.

Risk Assessment/Analysis:

- Likelihood determination
- Determination of impact
- Determination of risk

Strategies against Risk:

- **Risk avoidance**
- **Risk Transfer**
- **Risk Mitigation:** elimination or significant decrease of risk level (e.g., firewalls)
- **Risk Assignment/Acceptance**
 - **Risk Acceptance:** decided after weighing cost versus benefit of dealing with the risk. Must be documented and keep being monitored!
 - **Risk Assignment:** who is responsible for a risk? Ultimately, the organization owns the risk. Employees might be co-owners of the risk.

4. Countermeasure Selection

Considerations for countermeasures:

- Accountability
- Auditability
- Trusted source
- Independence
- Consistently applied
- Cost-effective
- Reliable
- Independence from other countermeasures (no overlap)
- Ease of use
- Automation
- Sustainable
- Secure
- Protects confidentiality, integrity, and availability of assets
- Can be “backed out” in event of issue
- Creates no additional issues during operation
- Leaves no residual data from its function

Organization must ensure that can support and maintain the remediation activities, once risk assessment is completed.

Tangible and Intangible Asset Valuation: periodically attempt to properly value information assets. Information may lose value over time, or if modified, improperly disclosed, or improperly valued.

Valuation methods: descriptive or metric. Some assets might need additional protection, e.g., because of regulatory compliance.

- **Tangible Asset Valuation** = (original cost – depreciation). The assessor needs to know the original cost and the replacement cost of the asset.

- **Intangible Asset examples:**

- Trademarks
- Patents
- Copyrights
- Business processes
- Brand recognition
- Intellectual property

Intangible assets might be definite (with an expiration period, e.g., patent), or indefinite (no expiration period, e.g., organization's brand).

Intangible Asset Valuation: Difficult to determine value for intangibles. For approximation the following methods are commonly used:

- Cost to create and replace the asset
- Capitalization of historic profits
- Cost avoidance or savings (e.g., avoid paying royalties because of a trademark acquisition)

5. Security Policies, Standards/Baselines, Procedures, Guidelines, and Documentation

- **Security Policy:** The statement of required protection of the information objects (NIST). Policies form the foundation of an organization's expectations for its employees. Guidelines for creating good security policies include:
 - Formally define a policy creation and policy maintenance practice
 - Policies should survive for two or three years (while being reviewed annually)
 - Do not be too specific in policy statements (focus on objectives, so as to avoid frequent updates, keep it concise, reduce redistribution and therefore confusion)
 - Use forceful directive wording
 - Technical implementation details do not belong in a policy
 - Keep each policy as short as possible
 - Provide references in policy to the supporting documents
 - Thoroughly review before publishing
 - Conduct management review and sign-off
 - Employees should acknowledge policies
 - Do not use technical jargon in policy language
 - Review incidents and adjust policies (adjust or redistribute)
 - Periodically review policies
 - Define policy exception rules
 - Develop sanctions for noncompliance

- Types of security policies:
 - Organizational or program policy
 - Functional, issue-specific policies
 - System-specific policies
- Standards: While policies focus on the organization's needs, standards take this a step further and define the specific requirements. Standards facilitate interoperability through the use of common protocols, and give a more technical perspective than policies. Hence, consistency in implementation is being achieved, while reducing confusion. Standards' creators include NIST, ISO, IEEE, ANSI, and NSA.
- Baselines: Baselines describe how to best implement the security configuration or standard so that it is consistent throughout the organization. They are the specific rules describing how to implement the best security controls in support of policy and standards.
- Procedures: Procedures are step-by-step instructions to support compliance with the policies and standards. Procedures should be developed with the input of each of the areas that might be impacted. Documenting procedures (that have been communicated to the involved parties) minimizes the legal liability of the corporation.
- Guidelines: Guidelines are discretionary or optional recommendations. They can also be recommendations, best practices and templates by other organizations (e.g., COBIT, CMM, ISO27000). Any standard, procedure or policy which is not mandatory can be viewed as guideline. Guidelines are by definition optional and can be made mandatory by some policies or standards.
- Documentation: All the aforementioned documents are closely related to each other. For ease companies tend to combine (some of) them. However, policies must not be combined with any other kind of documentation. Standards are best kept as standalone documents, too. This ensures that only appropriate management is involved in changing policies or standards.

Additional Reading/Source(s)

Glossary of Key Information Security Terms, by NIST.

CISSP Guide – "Security and Risk management" domain